Phishing Email Analysis: Headers, Attachments and Sender Impersonation

TryHackMe hands-on lab | Phishing Analysis Fundamentals | 2 November 2026

I investigated three saved email samples in an isolated lab environment. I read the message headers, recovered a PDF attachment without opening it, and examined an email impersonating Home Depot. This write up covers a guided training lab, not a production security incident, and I have kept the claims inside what the exercise actually gave me.

Goal / Objective

The aim was to take three suspicious emails and work out, for each one, who really sent it and whether it should be trusted. That meant going past the tidy view an email client shows and reading the message source underneath.

Four things I set out to do:

- Identify the real sender rather than the name shown in the From field.
- Read the delivery and authentication detail in the headers and work out what it actually proves.
- Examine an attachment without opening it or saving it to the machine.
- Record the indicators safely, so the notes could be shared without anyone clicking something by accident.

This is close to what happens in a SOC when a user forwards a suspicious email. Someone has to open it safely, reach a view on it, and leave notes the next analyst can follow.

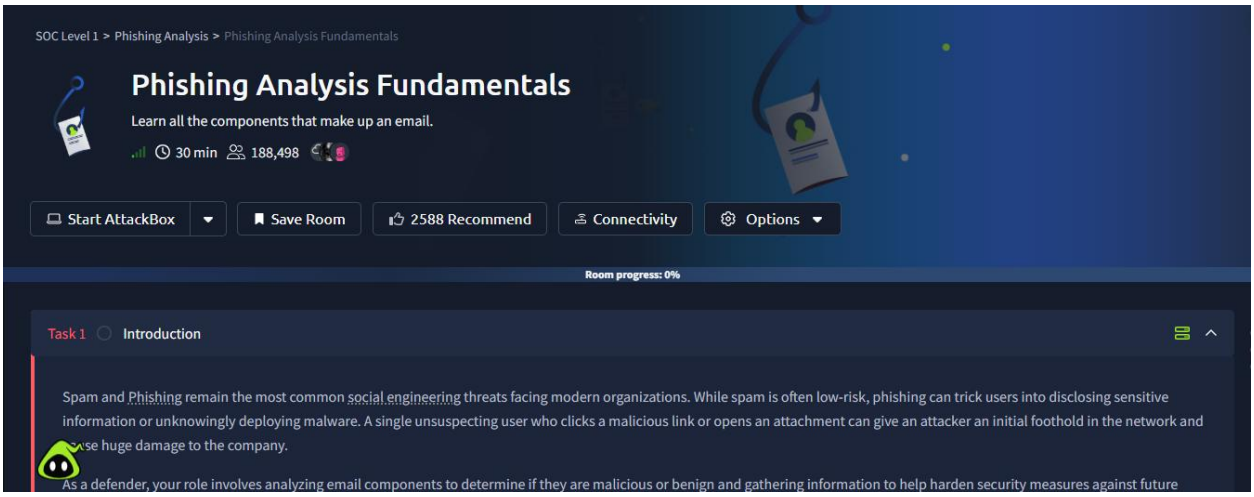


Figure 1. The lab at the start, before any samples were opened.

Tools Used

- TryHackMe Phishing Analysis Fundamentals room and its isolated Linux lab machine
- Mozilla Thunderbird, for opening the EML files and viewing the raw message source
- Mousepad text editor, for reading email2.txt directly
- CyberChef, using the From Base64, Render PDF and Defang IP Addresses operations

- Email headers, HTML body source and MIME attachment fields
- SPF, DKIM and DMARC authentication results
- MITRE ATT&CK, used to map what I observed

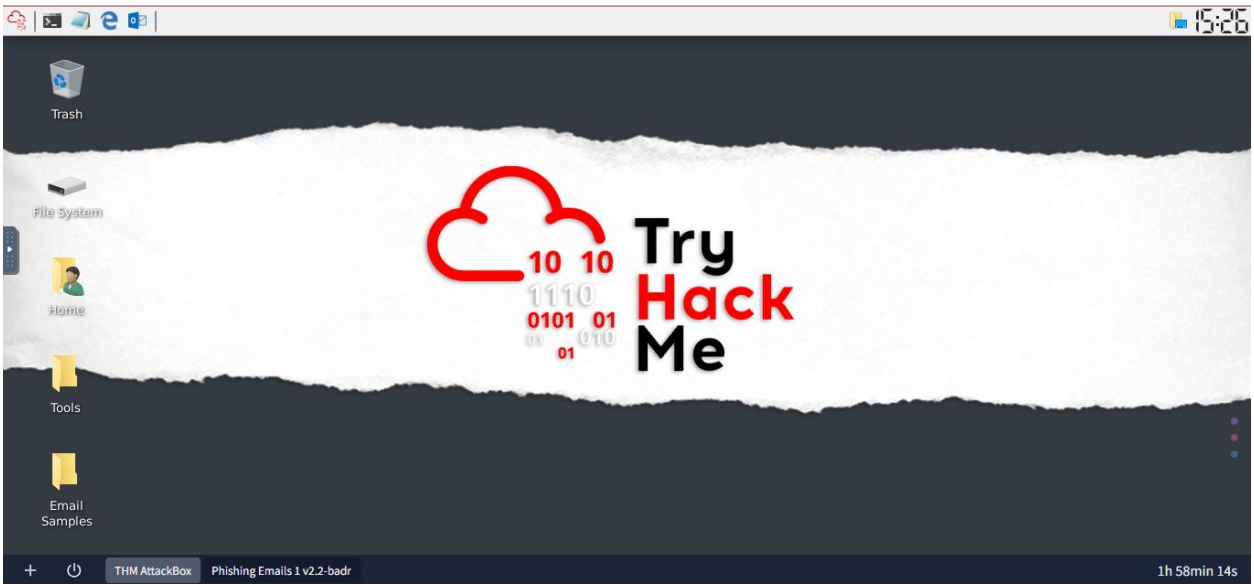


Figure 2. The isolated lab machine. All sample handling stayed here and nothing was copied to my own computer.

What I Did

1. Started the lab machine and confirmed I was on the correct host before touching any of the samples.
2. Opened the Email Samples folder and confirmed the three files provided: email1.eml, email2.txt and email3.eml.
3. Opened email1.eml in Thunderbird, compared the display name against the real sender, recipient and Reply-To address, then opened the raw message source and located the originating IP.
4. Recorded the SPF, DKIM and DMARC results for that message and worked out what they did and did not prove.
5. Opened email2.txt in a text editor and read the MIME fields for the attachment: content type, file name and transfer encoding.
6. Decoded the attachment in CyberChef with From Base64 and displayed it with Render PDF, rather than saving the file or opening it in a PDF reader.
7. Opened email3.eml, compared the brand claimed in the display name against the sending domain, and inspected the HTML body source to see where the main button pointed without following it.
8. Defanged the originating IP addresses in CyberChef before writing them into my notes.

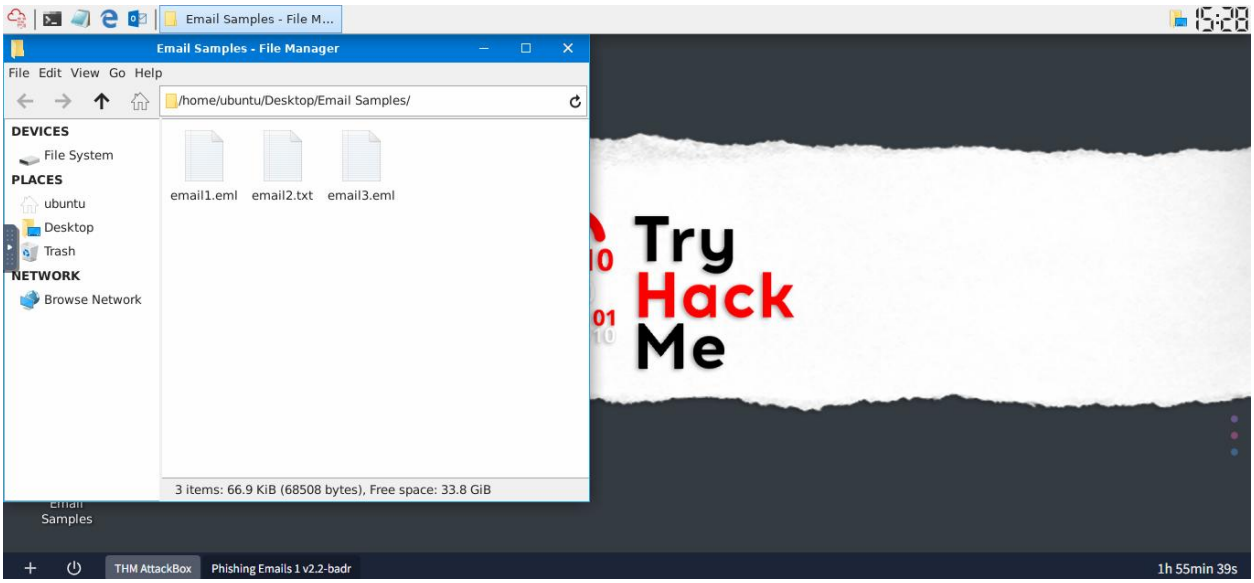


Figure 3. The three samples provided for analysis.

Investigation Summary

Email structure and delivery

The first part of the lab covered how an email address is put together and how a message actually gets delivered, using SMTP to send, DNS to find the receiving mail server, and POP3 or IMAP to collect. For the scenario involving a phone and a laptop I picked IMAP, because it leaves the messages on the server and keeps every device looking at the same mailbox.

The useful thing to come out of that section was a typosquat. The supplied address used tryhatme.com, which is one letter short of tryhackme.com. It is exactly the sort of thing the eye corrects on its own, and it is why I now read a domain character by character instead of glancing at it.

Email header investigation: email1.eml

The message presented itself as a home security promotion. The visible fields were:

- Display name: ADT Security Services
- From: newsletters@ant[.]anki-tech[.]com
- Reply-To: reply@ant[.]anki-tech[.]com
- To: alexa@yahoo.com
- Subject: Help protect your budget by protecting your home
- Date: 21 June 2021, 15:35

I recorded these without treating the display name as proof of anything. The display name is free text the sender types in, so a well known brand sitting there carries no weight on its own.

Thunderbird blocked the remote content and I left it blocked. Those images sit on the sender's own server, so loading them would have told the sender the message had been opened and roughly where from. That is not information I wanted to hand over mid investigation.

With the images blocked, what was left was a phone number, 1-844-674-3380, shown twice in large text. There was no link to inspect and no attachment to analyse. The whole point of the message was to get the reader to ring that number, which moves the attack onto a phone call where there is nothing for a mail filter to catch.

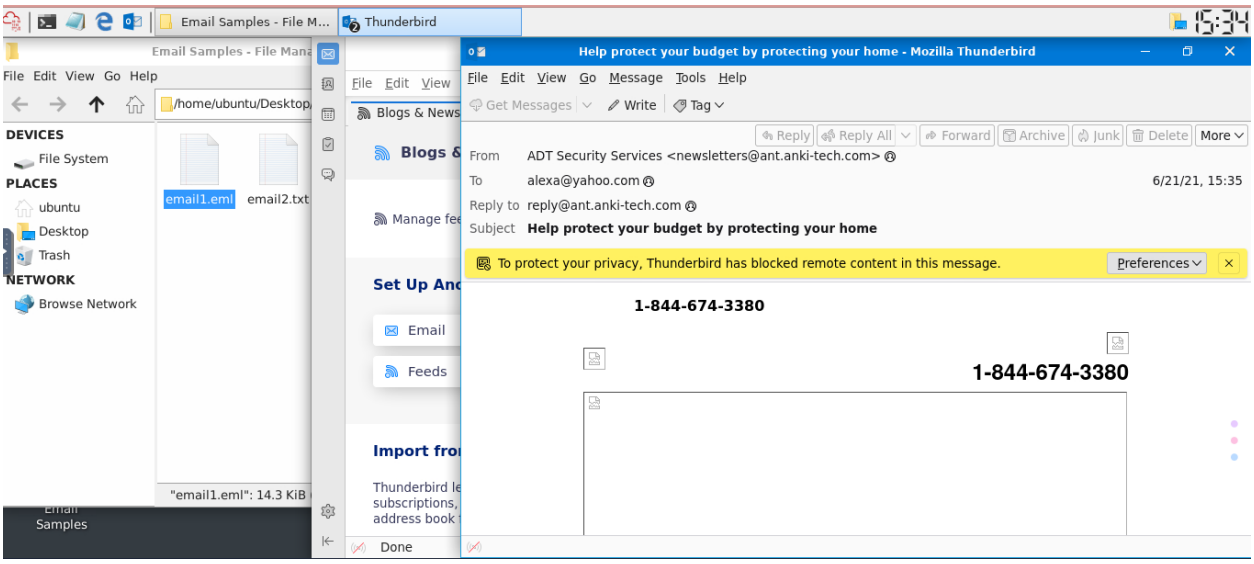


Figure 4. email1.eml as the recipient would see it, with remote content blocked and a phone number as the only call to action.

In the raw message source I found X-Originating-IP: 43[.]255[.]56[.]161. I was careful to take that field specifically rather than the nearest looking address, because the Received headers also hold addresses and they belong to the receiving servers, not the sender.

The authentication results read Received-SPF pass, dkim=pass, spf=pass and dmarc=pass with a policy of p=NONE.

This was the main judgement call in the investigation. Three green passes are easy to read as a clean message. What they actually confirm is that the message really was sent by whoever controls ant[.]anki-tech[.]com. They say nothing about whether that domain should be trusted, and an attacker using a domain they registered themselves is not impersonating anyone, so they pass every time. The DMARC policy of p=NONE also meant the domain owner had set no enforcement, so a failure would not have been acted on in any case.

I did not reach a final malicious or benign call on this message from the sender details alone. On what was in front of me I recorded it as suspicious: a bulk commercial message using a security brand in the display name, sent from an unrelated domain, with a callback number as the only action available.

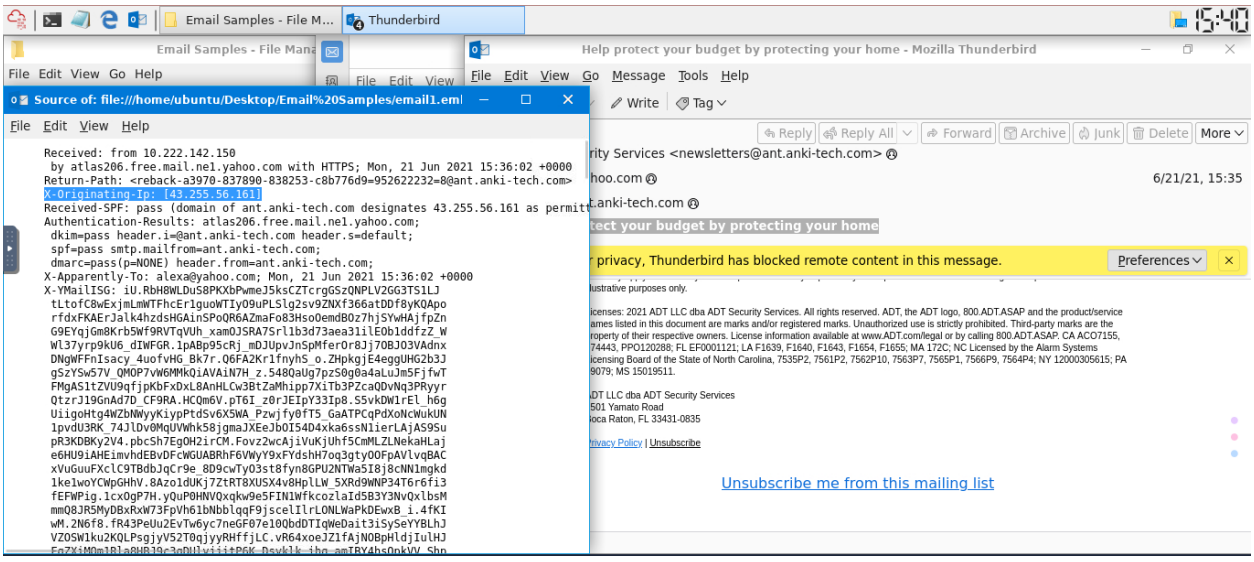


Figure 5. Raw message source for email1.eml showing the originating IP and the authentication results.

Attachment inspection and recovery: email2.txt

This sample was supplied as raw text so the attachment section could be read directly. The MIME fields described the attachment before I decoded anything:

- Content-Type: application/pdf
- Content-Disposition: attachment, file name zmqpalgh.pdf
- Content-Transfer-Encoding: base64

Those fields describe how the attachment was labelled and carried. They are not a safety verdict, and a file can be labelled as anything.

Two things were worth noting. The file name was eight random lowercase letters, which is what a script produces rather than what a business system or a person would choose. Real invoices and statements carry names a recipient would recognise.

The second was the start of the encoded block, JVBERi0x. Decoded, that is %PDF-1, the signature every PDF begins with. That let me confirm the attachment really was a PDF and not something renamed to look like one, which is a check worth doing because the extension is only part of the file name.

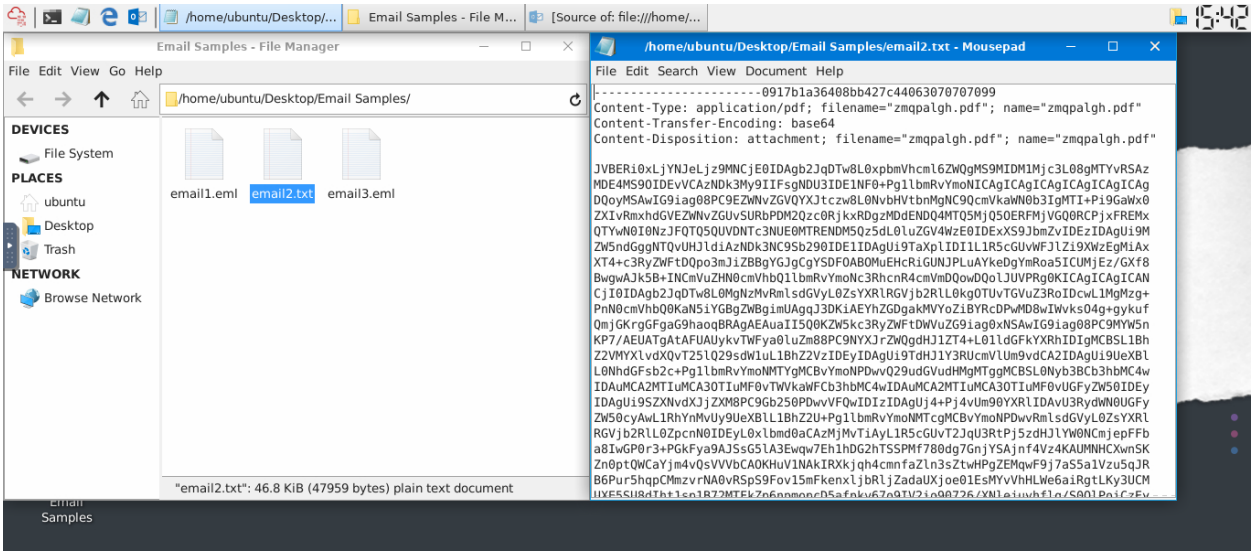


Figure 6. The attachment section of email2.txt showing the MIME fields and the start of the base64 encoded file.

I decoded the attachment with From Base64 in CyberChef and displayed it with Render PDF. That was deliberate. I did not save the file to the machine and I did not open it in a PDF reader, so nothing was written to disk and no local application parsed it. If the file had carried something aimed at a reader application, that path would not have set it off.

The recovered document held a single line of text and nothing else. No scripts, no embedded links, no automatic actions. The lab confirmed the attachment as benign. I should be clear that I did not run a full malware analysis on it, so what I can honestly say is that nothing active was present in what was rendered.

One thing I would do differently. The text I pasted into CyberChef included the trailing MIME boundary from the end of the attachment block. The PDF still rendered, but a clean extraction should contain only the base64 data. It worked here by luck rather than by care, and it is a preparation step I will check properly next time.

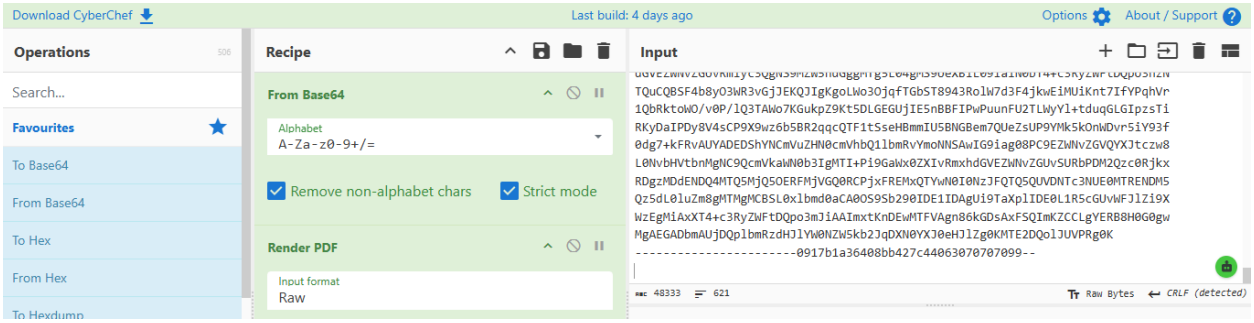


Figure 7. Decoding and rendering the attachment in CyberChef. The file was never saved to disk or opened in a PDF reader.

Recording a benign result properly matters as much as flagging a bad one. Being able to say that a file is clean, and show what was checked to decide that, is what lets a queue move instead of filling up with items nobody has closed out.

Phishing sample: email3.eml

This one presented itself as an order confirmation:

- Display name: Thank you! Home Depot
- Actual sender: support@teckbe[.]com
- To: alexa@yahoo.com
- Subject: Order Placed : Your Order ID OD2321657089291 Placed Successfully
- Date: 11 July 2021, 11:43

I identified Home Depot as the organisation being impersonated and treated the gap between the brand in the display name and the sending domain as the first clue. teckbe[.]com has no connection to Home Depot. I confirmed the real address directly from the sender field rather than relying on what was rendered on screen.

The subject line is doing specific work. Telling someone an order has gone through when they have not ordered anything creates confusion and a reason to act in a hurry. Confusion gets a click just as reliably as fear does.

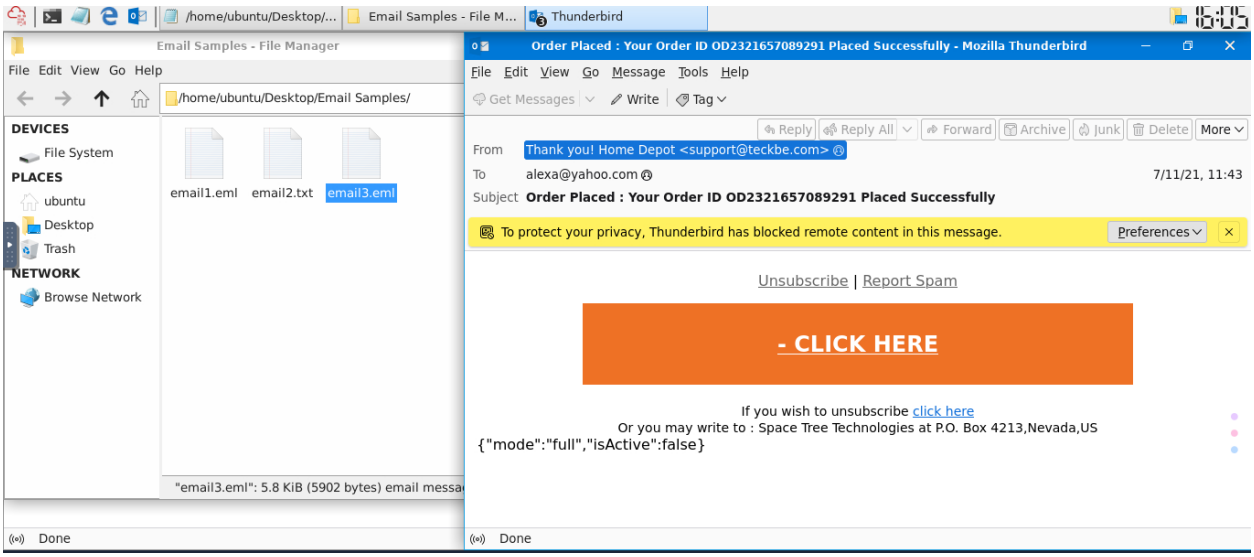


Figure 8. email3.eml. The display name says Home Depot, the sending domain does not.

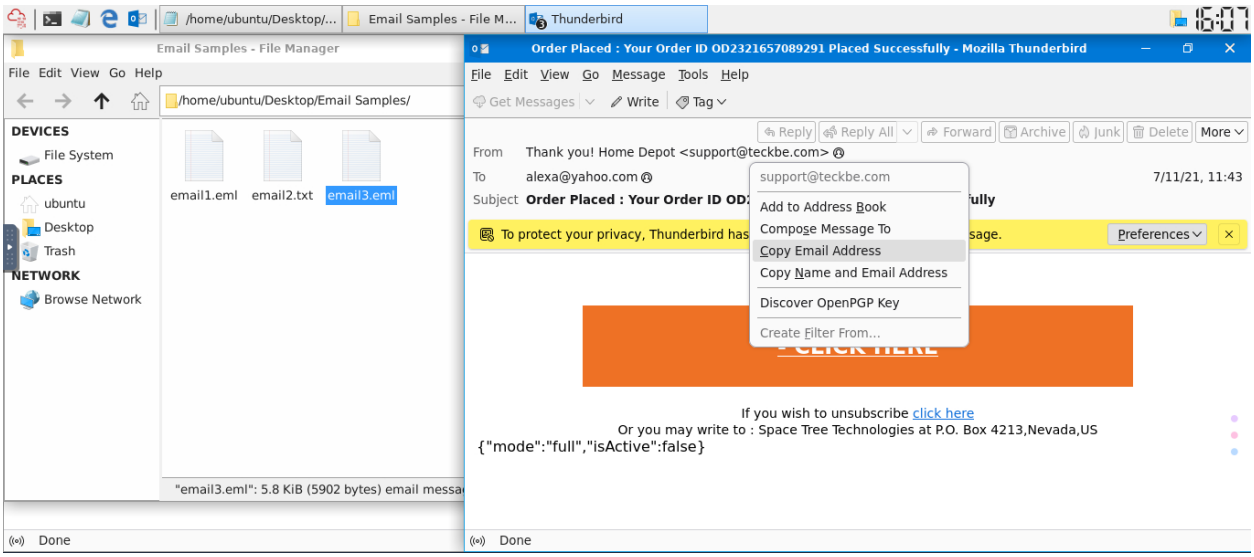


Figure 9. Confirming the real sender address directly from the sender field.

The body was close to empty. One large orange CLICK HERE button, an Unsubscribe link and a Report Spam link. There were no order lines, no prices, no delivery address and no customer details. A genuine order confirmation is full of that. This one carried none of it, because the only thing it needed was the click.

I read the HTML source rather than following anything. The CLICK HERE button pointed to t[.]teckbe[.]com, the sender's own subdomain, so the brand in the message and the destination of the button had nothing to do with each other. I also found a zero sized remote image in the source, which is consistent with a tracking pixel used to confirm the message had been opened. I did not test its behaviour.

The Unsubscribe and Report Spam links are worth treating the same way as the main button. They belong to the sender too, and clicking either one tells them the mailbox is live and being read.

One other detail: the body ended with a leftover fragment of configuration text, {"mode":"full","isActive":false}. That is debris from a bulk sending tool, left in by mistake. It proves nothing on its own, but it points to a mailing kit rather than a properly set up business mail system.

Authentication results and the decision

From the raw source I recorded:

- Return-Path: support@teckbe[.]com
- X-Originating-IP: 103[.]234[.]236[.]83
- Authentication-Results recorded by atlas102.free.mail.gq1.yahoo.com
- dkim=pass, spf=pass, dmarc=pass with a policy of p=NONE, all for teckbe[.]com

The same reasoning applied here as with the first sample, and this time it mattered more. The checks passing did not establish that the sender represented Home Depot, and they said nothing at all about whether the content was safe. They confirmed the message genuinely came from teckbe[.]com, which is the problem rather than a reassurance.

I classified the sample as phishing. The brand mismatch, the button pointing to the sender's own subdomain and the complete absence of order detail all supported that. No live alert, user click, credential theft or endpoint infection was part of this exercise, so I have not claimed an operational incident or any containment action.

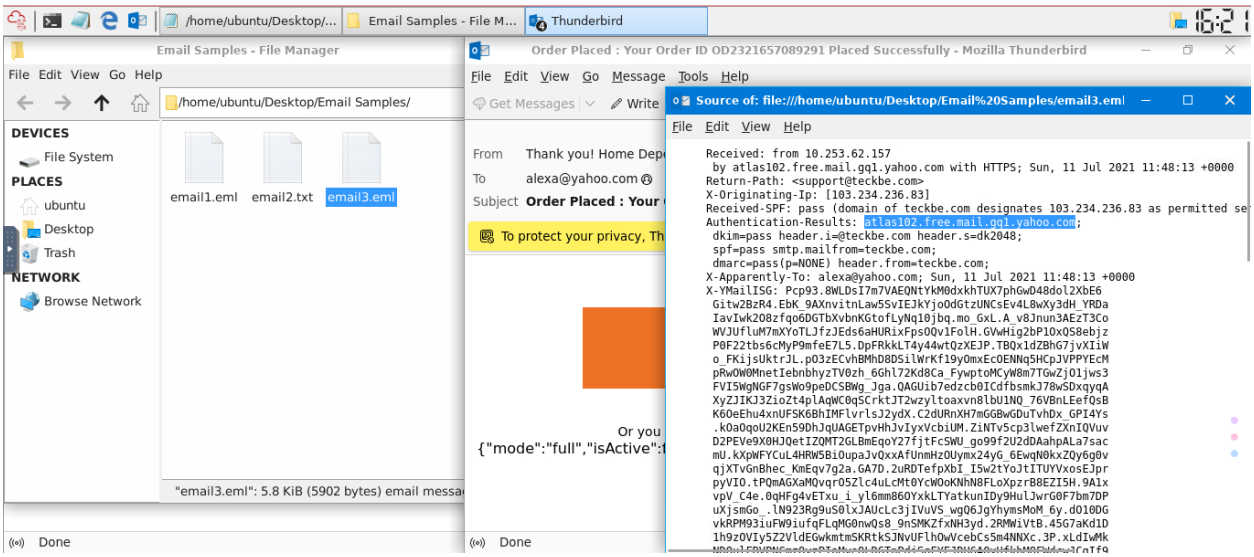


Figure 10. Raw message source for email3.eml showing the originating IP and the authentication results.

Handling the indicators

Before writing anything into my notes I defanged the IP addresses in CyberChef, so 103.234.236.83 became 103[.]234[.]236[.]83. Breaking the dots stops the address being clicked or turned into a live link by whatever application the report is read in. It takes seconds and it is the difference between a report that is safe to pass around and one that can get somebody into trouble by accident.

It is worth being clear about what defanging does. It changes how an indicator is written down. It does not make the destination any safer.

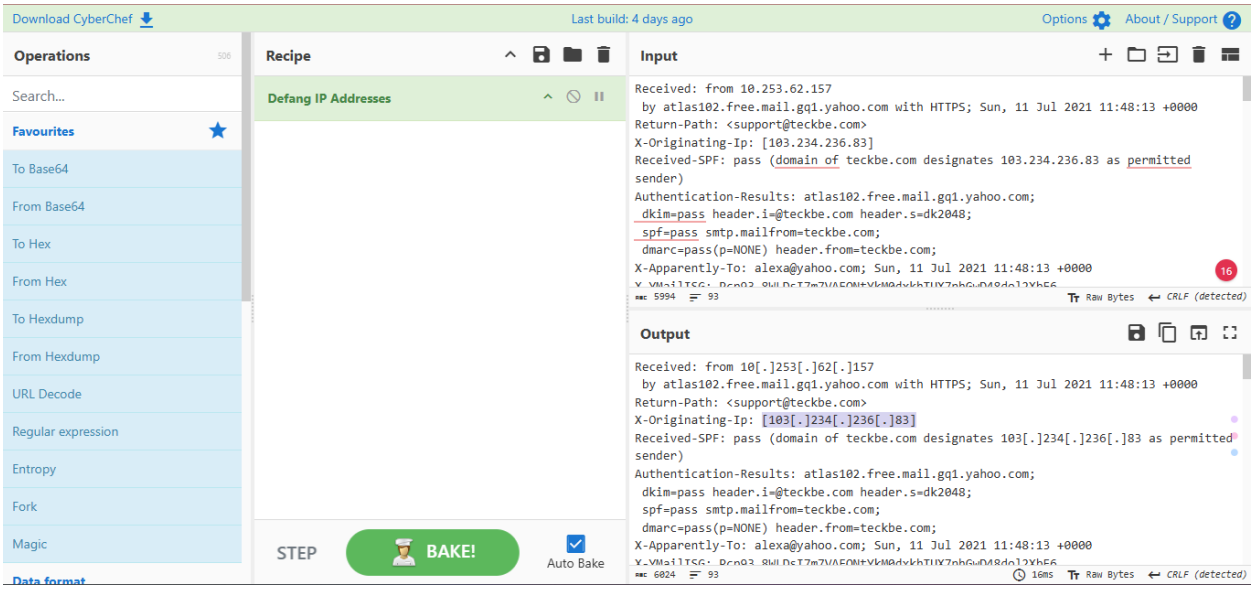


Figure 11. Defanging the extracted IP addresses before recording them.

Results / Findings

Assessments reached:

Sample	Assessment	What led me there
email1.eml	Suspicious	Bulk message using a security brand in the display name, sent from an unrelated domain, with a callback phone number as the only thing to act on.
email2.txt	Attachment benign	Recovered PDF held plain text only. No scripts, embedded links or launch actions visible. Confirmed benign by the lab.
email3.eml	Phishing	Home Depot in the display name, sending domain teckbe[.]com, a single click button pointing to the sender's own subdomain, and no order detail anywhere in the message.

Indicators recorded, defanged:

- newsletters@ant[.]anki-tech[.]com and reply@ant[.]anki-tech[.]com, sender and reply address for email1
- 43[.]255[.]56[.]161, originating IP for email1
- 1-844-674-3380, callback number used in email1
- zmqpalgh.pdf, attachment carried by email2, assessed as benign
- support@teckbe[.]com, sender for email3
- t[.]teckbe[.]com, destination of the CLICK HERE button in email3
- 103[.]234[.]236[.]83, originating IP for email3
- atlas102.free.mail.gq1.yahoo.com, the server that recorded the Authentication-Results header for email3

The finding that runs across all three samples is the one I would lead with. Every sample passed SPF, DKIM and DMARC, and two of the three were still suspicious or malicious. Those checks tell you whether a sender was impersonated. They do not tell you whether a sender is safe. Reading a pass as a clean verdict would have let both of these through.

Mapped to MITRE ATT&CK, this sits under T1566 Phishing. email3 fits the link based variant, T1566.002. email1 fits the voice based variant, T1566.004, since the email is only the lure and the attack itself happens on the call.

Skills Demonstrated

- Phishing email triage and brand impersonation detection
- Email header analysis, including From, Reply-To, Return-Path, Received and X-Originating-IP
- Interpretation of SPF, DKIM and DMARC results, including what a pass does and does not prove
- MIME attachment inspection, base64 decoding and file signature verification
- HTML body source review and identification of suspicious links without interacting with them
- Safe handling of unknown files, including rendering rather than opening and avoiding writes to disk
- Indicator of compromise extraction and defanging
- Use of CyberChef for decoding, rendering and data transformation
- Recognition of social engineering techniques, including callback phishing, manufactured urgency, tracking pixels and business email compromise
- MITRE ATT&CK technique mapping
- Evidence based assessment and investigation documentation
- Working inside an isolated analysis environment

What I Learned

The From line changed how I look at email. I had always read a sender address as a fact about a message. It is not. It is text the sender types, and anyone can type anything there. Once that landed, the rest of header analysis made sense, because it is all about finding the parts of an email the sender did not get to choose.

The biggest shift was around SPF, DKIM and DMARC. Before this I would have read three passes as a clean message and moved on. Both of the dodgy samples here passed all three. What those checks confirm is that the sender was not impersonated, and someone using their own domain is not impersonating anybody. I will not treat a pass as a verdict again. What I look at now is which domain was authenticated, which organisation the message claims to be from, and what it is asking the recipient to do.

Recovering the PDF made base64 much clearer. It is a way of writing file data as ordinary text so it can travel through a system built for text. It is not encryption and it is not protection. I also learned to separate the attachment data from the MIME boundaries around it, after my own pasted input included a trailing separator.

On handling, the lesson was render rather than open. Decoding the file and viewing it in the browser kept it off the file system and away from any reader application. That habit costs nothing and it is the right default for anything unknown.

A benign result is still a result. My instinct was that finding nothing meant I had not done anything useful. Writing up why the attachment was safe, and what I checked to decide that, took as much work as flagging a bad one.

I also made two practical mistakes worth recording. The first was reaching for a nearby technical value instead of the exact header a question asked for, which taught me to match the field precisely rather than grab the closest thing that looks right. The second was launching the general purpose attack box instead of the room's own lab machine, and spending a few minutes hunting for sample files on a system that was never going to have them. Nothing was lost except time, but in a real environment doing the right thing on the wrong machine is a much bigger problem than wasted minutes. Confirming which host I am on is now the first thing I do.

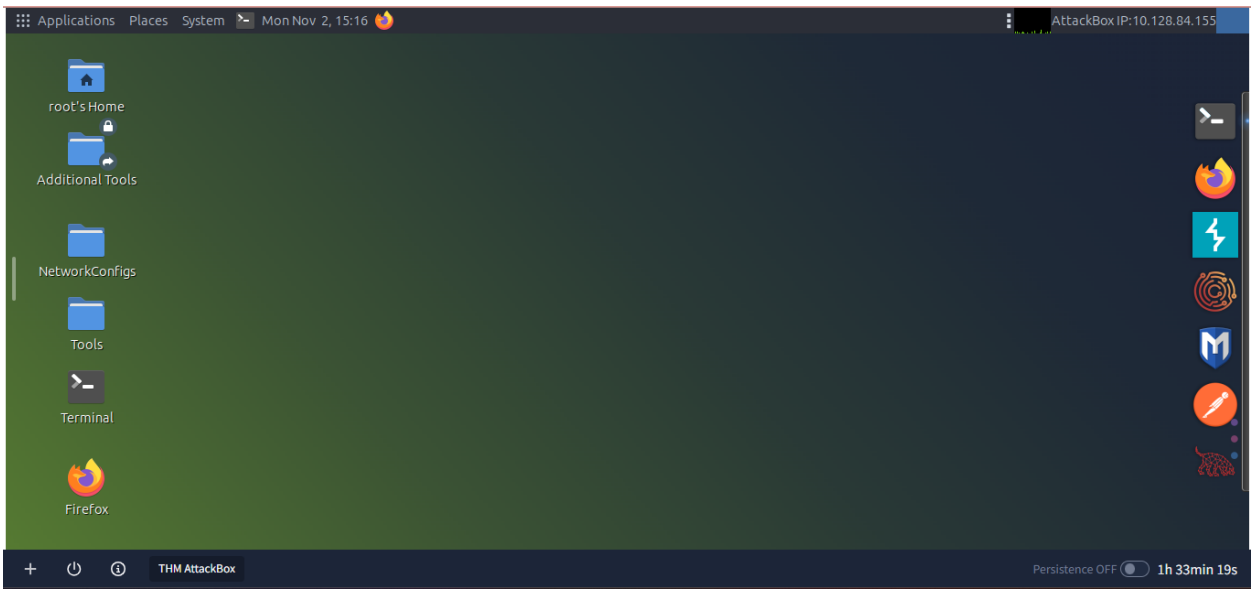


Figure 12. The wrong machine. Checking which host I am on before starting is now the first step.

Business email compromise gave me something to carry forward. When an attacker is sending from a mailbox they have actually taken over, nothing is faked, so every technical check passes and there is no odd domain to spot. The only thing left is whether the request itself makes sense. Tooling narrows the problem down, but the judgement at the end is still mine.

This investigation was guided, and I want to be straight about that. What it gave me was real practice in the work that sits under SOC email triage: gathering indicators, checking the evidence behind an assessment, and writing it down so someone else can follow it. My next step is to run the same process on fresh samples with less guidance, and to write my assessment before I check whether I was right.